COMPTIA SECURITY+ SY0-701 | DOMAIN 1 · GENERAL SECURITY CONCEPTS (12%)

Security+ 1.4 · Public Key Infrastructure (PKI)

Mestre CyberSec · **Lesson 1.4 — Public Key Infrastructure (PKI)** (9:08) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: PKI: o fundamento da criptografia moderna — SIMÉTRICA (AES — mesma chave, rápida, boa pra volume) vs ASSIMÉTRICA (RSA/ECC — par de chave pública/privada, lenta, boa pra troca e assinatura). Key escrow = cópia de chave em cofre.

💡 Key Exam Highlights & Critical Concepts

- AES = simétrico; RSA = assimétrico
- Assimétrico: pública cifra, privada decifra (ou assina)
- PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo)

🎯 Exam Tips & Typical CompTIA Scenarios

- 'requires a mathematical relationship between two cryptographic keys' = assimétrica (PKI)
- AES vs RSA: não confunde — a prova gosta de citar algoritmos

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 1.4 — Public Key Infrastructure (PKI))

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Public Key Infrastructure (PKI)

Framework of policies, roles, hardware, software, and procedures used to create, manage, distribute, store, and revoke digital certificates and public/private keys.

⚠️ ***Exam Trap:*** *Se a questão falar em certificados, CA, RA, CRL/OCSP e confiança em chaves públicas, o tema é PKI; não confunda com criptografia simétrica pura.*

• Advanced Encryption Standard (AES)

Symmetric block cipher using the same secret key to encrypt and decrypt data; fast and ideal for bulk encryption.

⚠️ ***Exam Trap:*** *"Mesma chave", "rápido", "bulk encryption" ou "simétrico" apontam para AES; não é usado para assinatura digital nem troca segura de chave por si só.*

• RSA (Rivest-Shamir-Adleman)

Asymmetric algorithm based on a mathematical relationship between a public key and a private key; used for key exchange, encryption, and digital signatures.

⚠️ ***Exam Trap:*** *Gatilho "requires a mathematical relationship between two cryptographic keys" = RSA/assimétrica; lembre: pública cifra/verifica, privada decifra/assina.*

• Elliptic Curve Cryptography (ECC)

Asymmetric cryptography using elliptic curves over finite fields to provide strong security with smaller key sizes than RSA.

⚠️ ***Exam Trap:*** *Se a prova pedir assimétrico com chaves menores/mobile/IoT, escolha ECC; não é simétrico como AES.*

• Key Escrow (N/A)

Secure storage of a copy of encryption keys by a trusted third party so data can be recovered if the original key is lost or unavailable.

⚠️ ***Exam Trap:*** *Gatilho "cópia da chave em cofre" ou "recuperação de chave" = key escrow; não é o mesmo que backup comum de dados.*

• Pretty Good Privacy (PGP)

Encryption program/protocol that combines asymmetric cryptography for key exchange/signatures with symmetric encryption for message content.

⚠️ ***Exam Trap:*** *Se a questão descrever "RSA para trocar a chave + AES para o conteúdo", pense PGP/híbrido; não diga que PGP é puramente simétrico ou assimétrico.*

• Certificate Authority (CA)

Trusted entity that issues, signs, and manages digital certificates, binding a public key to an identity.

⚠️ ***Exam Trap:*** *Quem assina o certificado é a CA; se a questão falar em validação de identidade antes da emissão, pode ser RA, mas a assinatura final é da CA.*

• Certificate Revocation List (CRL)

Published list of digital certificates that have been revoked before their expiration date and should no longer be trusted.

⚠️ ***Exam Trap:*** *CRL = lista baixada/consultada; OCSP = status online em tempo real. Se a pergunta citar "lista", escolha CRL; se citar "consulta online", escolha OCSP.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Chain of Trust: Root CA vs. Intermediate CA

🏫 **Real-World Analogy:** Think of a sovereign national passport authority. The Root CA is the central government archives locked inside an underground high-security mountain vault, whose master seal is accessed only once a decade under military escort. Because using that sovereign master seal for everyday public requests would expose it to immense risk, the vault delegates authority to Regional Consulate Offices (Intermediate CAs). These consulates interface with citizens and issue travel passports. If a regional consulate is compromised or catches fire, the central vault revokes only that intermediate branch without invalidating millions of passports across the rest of the nation.

🔍 **Root Cause & Background:** If a Root Certificate Authority were maintained online and connected to the internet to sign millions of everyday web requests, any server compromise or software defect would permanently compromise the master private key, collapsing cryptographic trust across the entire globe. An authoritative multi-tier PKI isolates the Root CA completely offline in air-gapped storage, delegating day-to-day issuance to Intermediate CAs to contain blast radius.

🛡️ **GRC Auditor Perspective:** GRC auditors must verify documentary evidence proving the enterprise Root CA is strictly air-gapped and held offline in a certified physical vault with dual-custody access controls. Auditors inspect recorded logs of the official 'Key Generation Ceremony' (conducted with independent witnesses) and ensure strict separation of duties between PKI policy administrators and subordinate CA operators.

⚠️ **How CompTIA Tests This:** CompTIA Exam Triggers: 'isolate the root certificate authority from network exposure' -> Offline Root CA; 'subordinate authority used for routine daily issuance' -> Intermediate CA; 'compromise of a signing authority without collapsing the entire trust model' -> Revoke the Intermediate CA.

📌 CSR (Certificate Signing Request) & Key Pair Generation

🏠 **Real-World Analogy:** Imagine applying for a verified government passport. In your own private home, you print a passport photo and collect your biometric fingerprint scan. You paste that public photo and your personal identity details onto a formal application petition (the CSR) and submit it to the passport agency (the CA). The agency validates your identity, applies an official tamper-evident holographic seal over your photo, and hands you the completed passport (the Digital Certificate). The agency never accesses your private home or safe; you only sent your public photo for authoritative endorsement.

🔍 **Root Cause & Background:** A server's private key must never leave its originating host or traverse network paths. If a Certificate Authority generated private keys on behalf of applicants, the CA would hold an identical copy and could impersonate the organization at will. The CSR mechanism was engineered so the applicant generates the key pair locally, locks the private key in hardware/keystore, and transmits only the public key and identity attributes for external signature.

🛡️ **GRC Auditor Perspective:** Audit enterprise CSR generation standards across all production systems. Confirm key lengths comply with NIST benchmarks (minimum RSA-2048 or ECC-256). Verify operational procedures guarantee private keys are never included within the CSR package and are flagged as non-exportable or anchored directly within hardware keystores (TPM/HSM).

⚠️ **How CompTIA Tests This:** CompTIA Exam Triggers: 'first step in requesting an SSL/TLS certificate from a public CA' -> Generate key pair and submit a CSR; 'what cryptographic element is contained in a CSR' -> The public key (classic trap: the PRIVATE key is NEVER included in a CSR).

📌 Certificate Revocation: CRL vs. OCSP vs. OCSP Stapling

🏠 **Real-World Analogy:** Imagine a cashier verifying stolen credit cards. A CRL (Certificate Revocation List) is like receiving a printed weekly phonebook containing every stolen card number nationwide: the merchant must page through thousands of entries during checkout (heavy network overhead, slow, and outdated between publication cycles). OCSP (Online Certificate Status Protocol) is like calling the card issuer's hotline during each transaction to ask 'is card #123 currently revoked?': it provides real-time verification, but millions of simultaneous queries swamp the issuer's servers, and the issuer monitors everywhere you shop. OCSP Stapling is like the web server proactively fetching a fresh, timestamped, digitally signed revocation clearance from the CA and attaching ('stapling') it directly into the initial TLS handshake: the browser validates it instantly without contacting the CA, eliminating query bottlenecks and protecting client browsing privacy.

🔍 **Root Cause & Background:** Digital certificates have long lifespans (typically 398 days), but if a server's private key is compromised on day two, the certificate must be invalidated immediately. Traditional CRLs generated massive bandwidth spikes and dangerous lag windows between periodic updates. While OCSP delivered real-time querying, it introduced privacy concerns (the CA tracked user destinations) and crippling server load. OCSP Stapling resolved both issues by shifting verification burden to the web host.

🛡️ **GRC Auditor Perspective:** Verify organizational PKI operations enforce real-time revocation handling and proactive lifecycle monitoring. Audit public-facing web server configurations to mandate OCSP Stapling (enhancing resilience, latency, and end-user privacy). Confirm network egress filtering permits boundary firewalls and forward proxies to resolve CA CRL distribution points and OCSP responders.

⚠️ **How CompTIA Tests This:** CompTIA Exam Triggers: 'periodic published list of invalid certificates causing bandwidth overhead' -> CRL; 'real-time check protocol for certificate validity' -> OCSP; 'web server appends a cached, time-stamped CA response to the TLS handshake to improve performance and privacy' -> OCSP Stapling.

📌 Key Escrow & M-of-N Split Knowledge Control

🏠 **Real-World Analogy:** Imagine an armored family estate safety deposit box in an official vault. If the estate executor passes away unexpectedly without sharing the combination, critical assets would be lost forever. Key Escrow is an independent escrow depository where a cryptographic recovery key is deposited under legally defined release triggers. To prevent any rogue custodian from opening the vault unilaterally, an M-of-N split knowledge scheme is enforced: the master recovery key is mathematically split into 5 distinct shards (N=5), requiring at least 3 authorized trustees (M=3) to insert their individual keys simultaneously to reconstruct the secret.

🔍 **Root Cause & Background:** If an employee who encrypted critical corporate intellectual property abruptly resigns, gets terminated, or passes away, the organization faces catastrophic permanent data loss without Key Escrow. Conversely, granting full escrow recovery power to a single administrator creates an unacceptable single point of compromise and insider threat, mitigated via M-of-N secret sharing (Shamir's secret sharing).

🛡️ **GRC Auditor Perspective:** Audit the enterprise key management policy against NIST SP 800-57 standards. Verify Key Escrow recovery procedures enforce immutable audit logging, formal legal authorization workflows, and strict multi-party custody (M-of-N / Dual Control / Split Knowledge) so no single administrator can unilaterally recover decrypted payloads.

⚠️ **How CompTIA Tests This:** CompTIA Exam Triggers: 'a third-party or secure repository holds cryptographic keys on standby for business or legal recovery' -> Key Escrow; 'requires a specified threshold of managers to assemble their key pieces to restore a master key' -> M-of-N control / Split Knowledge.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Root authority kept completely disconnected from the network to safeguard overall trust	**Offline Root CA**
File generated on the local server containing the public key submitted to a CA for signing	**CSR (Certificate Signing Request)**
Real-time query protocol to verify the revocation status of a specific individual certificate	**OCSP (Online Certificate Status Protocol)**
Web server attaches a cached time-stamped CA revocation response to the TLS handshake	**OCSP Stapling**
Secure storage of decryption keys held by a trusted party for lawful organizational recovery	**Key Escrow**
Security policy requiring at least 3 out of 5 designated custodians to combine secrets to unlock a master key	**M-of-N Control (Split Knowledge)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A healthcare organization needs to encrypt 500 GB of patient records on backup tapes that will be stored offsite. The security team requires strong encryption while minimizing processing overhead, since the encryption operation must complete within a tight nightly backup window. Which encryption algorithm should the team implement?

A) Advanced Encryption Standard (AES)

B) RSA with 4096-bit keys

C) Elliptic Curve Cryptography (ECC)

D) Diffie-Hellman key exchange

QUESTION 2 · EXAM SCENARIO

A software vendor distributes monthly updates to thousands of customers worldwide. The vendor wants customers to be able to verify that the updates originated from them and were not modified in transit. The vendor also wants to ensure that they cannot later deny having released a specific update. Which cryptographic approach should the vendor use to sign the updates?

A) Sign the update hash with the vendor's private key; customers verify with the vendor's public key

B) Sign the update hash with the vendor's public key; customers verify with the vendor's private key

C) Encrypt the entire update with the vendor's private key; decrypt with the vendor's public key

D) Encrypt the entire update with the vendor's public key; decrypt with the vendor's private key

QUESTION 3 · EXAM SCENARIO

A financial institution requires that all customer data remain accessible for a minimum of seven years per regulatory requirements. The chief risk officer is concerned that if an employee who originally encrypted the data leaves the company or loses their encryption key, the institution could be locked out of critical historical records. Which solution should the institution implement to mitigate this risk?

A) Key escrow with a trusted third party

B) Certificate Revocation List (CRL)

C) Public Key Infrastructure (PKI) certificate pinning

D) Perfect Forward Secrecy (PFS) rotation

QUESTION 4 · EXAM SCENARIO

An independent IT consultant regularly exchanges sensitive client contracts and strategic planning documents with a long-time business partner via email. They want to ensure that only the intended recipient can read the documents, and that the recipient can confirm the documents genuinely came from the consultant. Which technology is purpose-built for this scenario?

A) Pretty Good Privacy (PGP)

B) Server Message Block (SMB) signing

C) Wired Equivalent Privacy (WEP)

D) Lightweight Directory Access Protocol (LDAP) over SSL

QUESTION 5 · EXAM SCENARIO

A mid-sized company wants to deploy HTTPS across its internal web applications so that employees can verify they are connecting to legitimate company servers. The company needs an internal entity to vet server identities and issue the digital certificates that will be installed on those internal servers. Which component of PKI performs this function?

A) Certificate Authority (CA)

B) Registration Authority (RA)

C) Domain Name System Security Extensions (DNSSEC)

D) Online Certificate Status Protocol (OCSP) responder

QUESTION 6 · EXAM SCENARIO

An employee leaves the company, and the security administrator must immediately prevent any system from trusting the departing employee's smart card certificate, even though the certificate itself is still technically valid for another eleven months. Which PKI mechanism allows the administrator to invalidate the certificate before its natural expiration?

A) Add the certificate to a Certificate Revocation List (CRL) published by the CA

B) Wait for the certificate to expire and then reissue a new one

C) Reset the employee's smart card and reuse the same certificate serial number

D) Renew the certificate with the same public key but a new validity period

QUESTION 7 · EXAM SCENARIO

A startup is designing a new line of battery-powered IoT sensors that must securely authenticate to a cloud API using asymmetric cryptography. The sensors have a low-power ARM processor, only 64 KB of RAM, and operate for years on a single coin cell battery. The chief technology officer wants the strongest practical security without sacrificing battery life. Which asymmetric algorithm is best suited for these constraints?

A) Elliptic Curve Cryptography (ECC) using a 256-bit key

B) RSA using a 4096-bit key

C) RSA using a 2048-bit key

D) Triple DES (3DES) using three 56-bit keys

QUESTION 8 · EXAM SCENARIO

During a TLS handshake between a user's browser and a web server, the browser must securely transmit a randomly generated symmetric session key to the server. After this exchange, all subsequent application data is encrypted using the shared symmetric key because symmetric encryption is far more efficient. Which key does the browser use to encrypt the session key before transmitting it to the server?

A) The server's public key obtained from the server's digital certificate

B) The server's private key stored on the web server

C) The browser's public key sent in the ClientHello message

D) The browser's private key stored in the user's certificate store

QUESTION 9 · EXAM SCENARIO

A database administrator must encrypt a 10 GB production database backup file that will be archived to long-term storage. The same trusted administrators who need to restore the file in a disaster recovery scenario will hold the key, and the encryption operation must complete within the available maintenance window. Which type of encryption is most suitable for this scenario?

A) Symmetric encryption using AES-256 with a shared secret key

B) Asymmetric encryption using RSA with a 2048-bit key

C) Asymmetric encryption using ECC with a 256-bit key

D) Hybrid encryption using only Diffie-Hellman for the data payload

QUESTION 10 · EXAM SCENARIO

A multinational corporation is deploying a PKI to support 40,000 employees, 500 internal servers, and several partner-facing applications. Rather than issuing every certificate directly from a single root, the architects design a model where a single offline root CA signs the certificates of several intermediate CAs, which in turn issue certificates to end-entity servers and users. What is this hierarchical trust model called?

A) Chain of trust (hierarchical PKI)

B) Web of trust

C) Trust anchor federation

D) Self-signed certificate pool

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Advanced Encryption Standard (AES)

AES is a symmetric encryption algorithm that uses the same key for encryption and decryption. For large volumes of data like 500 GB, symmetric encryption is dramatically faster and more efficient than asymmetric algorithms such as RSA or ECC. Asymmetric cryptography is reserved for key exchange and digital signatures due to its computational overhead. AES-256 provides strong, FIPS-approved encryption suitable for regulated healthcare data.

Question 2: Option A — Sign the update hash with the vendor's private key; customers verify with the vendor's public key

To provide both integrity and non-repudiation, the vendor must sign the update with their private key. Only the vendor has access to this private key, so only the vendor could have produced the signature. Customers use the vendor's widely distributed public key to verify the signature and confirm the update has not been altered. Encrypting the whole file is inefficient and unnecessary; signing the hash provides the same guarantees at a fraction of the cost.

Question 3: Option A — Key escrow with a trusted third party

Key escrow is the practice of securely storing a copy of encryption keys with a trusted third party or in a hardened internal vault. This ensures that encrypted data can be recovered even if the original key holder is unavailable, loses their key, or leaves the organization. It is commonly used in regulated industries to meet data retention requirements. CRL, certificate pinning, and PFS do not address the recovery of encryption keys.

Question 4: Option A — Pretty Good Privacy (PGP)

Pretty Good Privacy (PGP) is specifically designed to secure email and file communications between individuals. It uses a combination of symmetric encryption (for the message body) and asymmetric encryption (to protect the symmetric key), along with digital signatures for authenticity and non-repudiation. SMB signing protects file shares, WEP is an obsolete wireless security protocol, and LDAPS secures directory queries — none address secure email between two parties.

Question 5: Option A — Certificate Authority (CA)

A Certificate Authority (CA) is the trusted entity within a PKI that verifies the identity of certificate requesters and issues signed digital certificates binding a public key to an identity. The CA's signature on the certificate allows relying parties to trust the binding. An RA only verifies identities and forwards requests to a CA; DNSSEC protects DNS records; and OCSP responders report certificate status. None of these actually issue certificates.

Question 6: Option A — Add the certificate to a Certificate Revocation List (CRL) published by the CA

A Certificate Revocation List (CRL) is a signed, time-stamped list published by the issuing CA that identifies certificates that have been revoked before their scheduled expiration. Relying parties consult the CRL during certificate validation to ensure they are not accepting a revoked certificate. Waiting for natural expiration leaves an unacceptable security gap; reusing serial numbers is cryptographically dangerous; and renewing with the same key does not address the trust loss.

Question 7: Option A — Elliptic Curve Cryptography (ECC) using a 256-bit key

Elliptic Curve Cryptography (ECC) provides equivalent security to RSA while using dramatically smaller key sizes — a 256-bit ECC key offers comparable strength to a 3072-bit RSA key. Smaller keys mean smaller certificates, less memory consumption, faster computations, and significantly lower power draw. 3DES is a symmetric algorithm and is obsolete regardless of use case. The chosen RSA key sizes would either be too power-hungry or insufficient for long-term security.

Question 8: Option A — The server's public key obtained from the server's digital certificate

The browser encrypts the symmetric session key with the server's public key, which it retrieves from the server's digital certificate during the handshake. Only the server's matching private key can decrypt this value, ensuring that no eavesdropper can recover the session key even if the exchange is intercepted. After both sides possess the session key, they switch to symmetric encryption for bulk data transfer due to its performance advantages.

Question 9: Option A — Symmetric encryption using AES-256 with a shared secret key

Symmetric encryption such as AES-256 uses a single shared secret key for both encryption and decryption and is orders of magnitude faster than asymmetric algorithms. Since the same personnel need to both encrypt and decrypt the archive, sharing the symmetric key is operationally straightforward. Asymmetric encryption of 10 GB of data would be prohibitively slow, and Diffie-Hellman is a key agreement protocol, not a data encryption algorithm.

Question 10: Option A — Chain of trust (hierarchical PKI)

A chain of trust, also called hierarchical PKI, is the most common PKI topology. Trust flows from a single root CA down through one or more intermediate CAs to end-entity certificates. Each certificate is signed by the entity immediately above it in the hierarchy, so verifiers can trace trust back to a known root. A web of trust is the decentralized model used by PGP; there is no single anchor. Trust anchor federation and self-signed certificate pools are not standard PKI trust models.